DNSは証明書管理の信頼境界になった：サーバ証明書発行のDNS依存の体系化と運用統制の提案

水元 明法[1,a)]　鈴木 彦文[1]　佐藤 周行[1]

概要：サーバ証明書の発行は，CAA レコードによる発行可否の制御，DNS レコードによるドメイン管理権の確認（DCV），複数視点による発行裏付け（MPIC）と DNSSEC 検証によるそれらの信頼性担保という三つの系統を通じて，DNS に構造的に依存するようになった．本稿は，可決済みの CA/Browser Forum 要件と確立した RFC に基づき，この依存が形成された経緯を体系的に整理する．特に，2025 年から 2026 年にかけて適用が始まった一連の要件により，DNS の設定不備が証明書の発行停止を経てサービスの可用性に波及する経路が生じたことを示す．そのうえで，証明書管理の対象が鍵・設定・発行状況に加えて DNS の健全性へ拡張されたこと，すなわち証明書管理の信頼境界が DNS にまで拡張されたことを踏まえ，DNS 管理を，変更時の審査，定期の監査，およびそれらを支える体制と手続きの整備という三つの類型で統制する枠組みを提案する．

キーワード：サーバ証明書，DNS，DNSSEC，信頼境界，運用統制

DNS as the Trust Boundary in Certificate Management: Systematizing DNS Dependency in TLS Server Certificate Issuance and Proposing an Operational Governance Framework

Akinori Mizumoto[1,a)]　Hikofumi Suzuki[1]　Hiroyuki Sato[1]

Abstract: The issuance of TLS server certificates has become structurally dependent on DNS through three mechanisms: issuance control via CAA records, domain control validation (DCV) via DNS records, and the assurance of these checks via Multi-Perspective Issuance Corroboration (MPIC) and DNSSEC validation. Based on adopted CA/Browser Forum requirements and established RFCs, this paper systematically reviews how this dependency has developed. In particular, we show that a series of requirements that took effect in 2025 and 2026 created a path by which DNS misconfiguration can halt certificate issuance and ultimately threaten service availability. We then argue that certificate management now extends beyond keys, server configuration, and issuance status to the health of DNS itself, and that the trust boundary of certificate management has thereby expanded to include DNS. On this basis, we propose a framework that governs DNS management through three types of controls: pre-change review, periodic audit, and the organizational structures and procedures that support them.

Keywords: TLS server certificate, DNS, DNSSEC, trust boundary, operational governance

1. はじめに

サーバ証明書の管理は，従来，おおむね次の三つの作業からなるとされてきた．秘密鍵を安全に保管すること，サーバへの導入と設定を正しく行うこと，そして有効期限と発行状況を把握し，失効や更新を漏れなく回すことである．長らく，この三点を押さえておけば証明書の運用は成り立っていた．

しかし，ここ数年でその前提は変わった．証明書の発行

[1] 国立情報学研究所
National Institute of Informatics
[a)] mizumoto@nii.ac.jp

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

プロセスそのものが，DNS に深く依拠するようになったためである．どの CA に発行を許すか，ドメインを管理しているのは誰か，その確認は信頼できる経路で行われたか．これらの判断のいずれもが，いまや DNS を参照して下される．結果として，DNS の状態は名前が引けるかどうかというインフラ上の関心事にとどまらず，証明書が発行できるかどうかを左右する要素へと格上げされた．

本稿の結論を先に述べておく．サーバ証明書の管理は，鍵・設定・発行状況という従来の三点に加えて，DNS の管理にも及ぶようになった．DNS の健全性は，証明書管理に加わった第四の対象というべき位置を占めるに至ったのである．両者の関係はもはや不可分であり，運用者はその密接さを認識したうえで，DNS の健全性を証明書とサービスの可用性の問題として運用設計に組み込む必要がある．

本稿は，近年ますます厳格さが求められるようになった証明書管理を運用者の視点から整理し，DNS を新たな信頼境界として位置づけたうえで，その境界を保つための運用上の方法論を示すものである．新たな方式や測定データを提示する研究論文ではなく，確定した標準群に依拠する解説論文であり，その貢献は三つある．第一に，DNS が証明書発行に関与する経路を，発行可否の制御，ドメイン管理権の確認，確認の信頼性担保という三つの系統として体系化し，個別に報じられてきた一連の要件変更を一つの見取り図に収めたことである．第二に，DNSSEC 検証必須化の要件が持つ，導入は任意だが導入したなら設定の健全性が発行の前提条件になるという非対称な構造を明確にしたことである．第三に，これらの帰結として拡張された DNS の管理を，審査，監査，およびそれらを支える体制という三つの類型として実務の作業体系に落とし込んだことである．

以下の本文では，この変化がどのような標準と要件の積み重ねによって生じたのかを，事実に基づいて整理する．なお本稿は，可決済みの CA/Browser Forum 要件と，確立した RFC に記述を限定する．現在進行中の議論や未確定のドラフトには立ち入らない．

本稿の構成は次のとおりである．2 節で DNS が証明書発行に関与する三つの系統を整理し，3 節で関連研究を概観する．4 節では，各系統の経緯をそれぞれ追ったうえで，それらを時系列に並べ直す．5 節では，運用者側への実務的な含意を論じ，DNS 管理を統制する枠組みを示す．6 節で結論を述べる．

2. 証明書発行に関わる DNS の三つの系統

DNS が証明書発行に関与する経路は，大きく三つの系統に分けて捉えられる．

第一は，発行可否の制御である．ドメイン所有者が DNS 上でどの CA に発行を許すかを宣言し，CA はそれに従う．CAA（Certification Authority Authorization）レコードを中心とする系統であり，本稿では便宜的に（A）系統と呼ぶ．

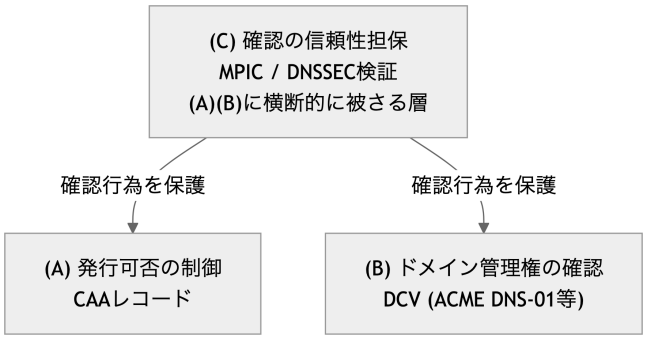


図 1　証明書発行に関わる DNS の三系統の構造

Fig. 1　Structure of the three DNS mechanisms involved in certificate issuance.

第二は，ドメイン管理権の確認である．証明書を申請した者が，対象ドメインを実際に管理しているかを DNS レコードの設置によって確かめる．いわゆる DCV（Domain Control Validation）であり，ACME の DNS-01 に代表される．これを（B）系統と呼ぶ．

第三は，確認の信頼性担保である．これは他の二つと性格を異にする．（A）も（B）も DNS が証明書発行で果たす機能であるのに対し，第三の系統はそれらと並ぶ別個の機能ではなく，（A）と（B）の確認行為そのものに被さる横断的な層である．CA が CAA や DCV を確認する，まさにその行為が，改竄や偽装に対して頑健であることを保証する仕組みであり，MPIC（複数視点による発行裏付け）と DNSSEC がこれを担う．これを（C）系統と呼ぶ．

全体像を整理すると，（A）と（B）が並列の機能として存在し，その両方に（C）が層として重なる構造になっている（**図 1**）．次節で関連研究を概観したのち，4 節でこの三系統をそれぞれ追っていく．

読み進めるあいだ，（C）が（A）と（B）に被さる層であることを念頭に置いておくと，信頼性担保の節で観測点の分散や署名検証の話が現れたときに，それが宙に浮かず，確認行為の信頼性を支える話として収まるはずである．

3. 関連研究

証明書発行と DNS の関係は，研究の面からも複数の角度で扱われてきた．本節では，本稿に関わる先行研究を三つの群に分けて概観し，本稿の位置づけを明らかにする．

第一は，検証行為への攻撃可能性を実証した研究である．Birge-Lee らは，BGP ハイジャックによってドメイン検証を欺き，正規の CA から証明書を不正取得できることを実証した [1]．Brandt らは，DNS 層への攻撃によって同様の不正取得が可能であることを示し，分散した観測点からの検証を対策として提案した [2]．Birge-Lee らはさらに，複数視点からの検証を Let's Encrypt に実装し，大規模 CA における実運用の経験を報告している [3]．これらは，本稿

© 2026 Information Processing Society of Japan

でいう（C）系統，すなわち MPIC と DNSSEC 検証必須化が標準化される動機となった研究群である．

第二は，防御機構の普及と運用実態の測定研究である．Chung らは，DNSSEC の署名や鍵管理に不備のあるドメインが広範に存在することを大規模測定によって示した [4]．Scheitle らは，CAA チェック義務化前後の CAA レコードの普及状況と設定不備を測定した [5]．Liu らは，役割を終えたまま放置された DNS レコード（dangling DNS レコード）がドメイン乗っ取りと証明書の不正取得の足がかりになることを明らかにした [6]．

第三は，運用と実装の報告である．Aas らは，ACME プロトコルに基づく証明書の自動発行を大規模に実現した Let's Encrypt の設計と運用を報告した [7]．Müller らは，DNSSEC の鍵更改が運用上の困難を伴う作業であることを整理している [8]．

これらの先行研究は，個々の要素技術の攻撃可能性や普及実態を明らかにしたものであり，本稿でも記述の随所で論拠として参照する．国内に目を向けると，DNS とサーバ証明書の関係の変化を運用者向けに解説した講演資料が早くからある [9]．ただしこれは，CAA チェックの義務化と ACME の普及までを扱った 2018 年時点のものであり，本稿が主題とする 2024 年以降の一連の要件には及んでいない．著者らの知る限り，これらの知見と一連の標準化の動きを，証明書管理という運用者の作業体系の側から統合し，要件変更の帰結を管理対象の拡張として整理した文献は見当たらない．標準文書と実証研究のあいだを運用者の視点で橋渡しする点に，本稿の位置づけがある．

4. DNS と証明書管理の接近

本節では，前節で示した三つの系統が，どのような標準と要件の積み重ねによって形づくられてきたのかを順に追い，最後にそれらを時系列に並べ直して全体の趨勢を確かめる．

4.1 発行可否を制御する DNS

発行可否の制御を担うのが CAA レコードである．これは，ドメイン所有者が DNS 上でこのドメインに証明書を発行してよい CA を明示できる仕組みで，2013 年に RFC 6844 として標準化された [10]．`issue` タグや `issuewild` タグに自らが許可する CA を列挙しておけば，そこに含まれない CA は発行を控えるべきだという意思表示になる．ただし登場当初，CAA の位置づけはあくまで任意であった．CA は CAA レコードを参照してもよいが，しなくてもよい．ドメイン所有者が宣言を書いても，それを無視して発行する CA が規約違反になるわけではなく，仕組みとしては存在するが実効性の保証がない状態だったのである．

この状況が変わったのが 2017 年である．CA/Browser Forum の Ballot 187 により，CAA レコードのチェックがすべてのパブリック CA に義務化された [11]．同年 9 月 8 日以降，CA は証明書を発行する前に CAA レコードを探索し，`issue`/`issuewild` タグに自らが含まれない場合は発行を拒否しなければならなくなった．これは，DNS を発行可否の権威ある情報源として位置づけた最初の大きな転換点である．ドメイン所有者の DNS 上の宣言が，CA の発行判断を規約的に拘束するようになった．DNS が，単なる名前解決の場から，証明書発行を制御する場へと役割を広げた瞬間といってよい．

CAA の表現力は，その後さらに拡張された．2019 年 11 月，CAA の仕様は RFC 6844 を置き換える RFC 8659 として再編され [12]，同時に発行された RFC 8657 は，CAA レコードに付与できる拡張パラメータとして `accounturi` と `validationmethods` を定義した [13]．前者は発行を特定の ACME アカウントに限定し，後者は許可する検証方法を限定するものである．これにより，どの CA に許すかだけでなく，どのアカウントが，どの方法でなら発行してよいかまでを DNS で表現できるようになった．もっとも，これらのパラメータは定義されてから長らく，CA による処理が任意のままであった．仕組みは用意されていても，CA がそれを解釈する義務はなく，書いても無視されうる状態が続いていたのである．

この宙吊りの状態に決着をつけたのが，2026 年 5 月に可決された Ballot SC098v2 である [14]．これにより CA は，2027 年 3 月 15 日以降，RFC 8657 で定義された CAA パラメータを処理することが義務づけられる．発行ポリシーを DNS 側でより精緻に指定し，それを CA が必ず尊重する仕組みが整うことになる．CAA の系譜は，任意の宣言から始まり，チェックの必須化を経て，パラメータ処理の必須化へと至った．発行可否の制御は，DNS 上でかなりきめ細かく，かつ強制力を伴って行える段階へと進みつつあるのである．

4.2 ドメイン管理権を確認する DNS

発行可否の制御と並ぶもう一つの系統が，ドメイン管理権の確認（DCV）である．そして，この確認手段もまた，DNS ベースへと大きく傾いていった．その牽引役となったのが，ACME プロトコルとその普及である [7], [15]．とりわけ DNS-01 チャレンジは，`_acme-challenge` という名前の TXT レコードに，CA が指定する検証用の文字列を設置することで，申請者がそのドメインの DNS を管理していることを証明する方式である．さらに，ワイルドカード証明書は DNS ベースの検証でしか取得できず，ACME においては DNS-01 がその唯一の手段であるという事情も，DNS ベース DCV の重要性を一段と高めた．サーバにファイルを置く方式では，ワイルドカードが対象とする不特定多数のホストを代表して管理権を示すことができないためである．

© 2026 Information Processing Society of Japan

ACME の普及と前後して，Baseline Requirements の側でも，DNS レコードを用いた DCV メソッドが整理されていった．代表的なのは，対象ドメインの TXT レコードにリクエストごとのランダム値やトークンを設置し，その存在を確認する方式である（BR 3.2.2.4.7）[16]．同じ規定は CNAME レコードや CAA レコードに検証値を置く形も許容しているが，CNAME はむしろ検証用の名前を別ゾーンへ委譲する用途で使われ，CAA は本来の発行可否制御に用いられるのが実態で，検証値の器としての主役は TXT である．こうして DNS は，DCV の主要な手段の一つとして定着した．この流れの延長線上で，検証用の DNS レコードを毎回設置・削除する従来型に加え，有効期限まで再利用できる永続的な TXT レコードを用いる方式も後に加わった（SC088v3，2025 年 11 月 11 日適用開始）[17]．ただしこれは，CA がこの方式を採用してよいという標準上の根拠が整ったことを意味するにとどまる．実際に利用できるかどうかは各 CA の対応状況により，すべての CA で直ちに使えるわけではない点には注意が必要である．この永続化が運用上どのような意味を持つかは，5.1 節で改めて取り上げる．

DNS ベースの DCV を理解するうえで避けて通れないのが，Authorization Domain Name（ADN，認可ドメイン名）という概念である．これは証明書に含めたい FQDN について，発行の認可を得るために用いる FQDN を指す．ADN の扱いには，いくつかの規則が伴う．CA は，CNAME ルックアップで返った FQDN を検証用の FQDN として用いることができる．ワイルドカードの場合は左端の`*.`を除去する．そして，対象 FQDN の左から右へドメインラベルを段階的に刈り込み（prune），Base Domain Name に至るまでの任意の値を検証に使うことができる．たとえば `www.example.ac.jp` の管理権確認のために，`example.ac.jp` を用いることが許される．CNAME を辿る挙動（CNAME チェイニング）やラベルの刈り込みは，検証の柔軟性を生む一方で，どの DNS クエリが管理権確認に関与するのかを複雑にする．この複雑さは，4.3 節で述べる DNSSEC 検証の対象範囲とも直結する．どの名前を，どの経路で引いたかが，信頼性担保の対象を決めるからである．

4.3 確認の信頼性を担保する DNS

前の二つの項で見たのは，DNS が証明書発行の機能を担うようになった経緯である．本項で扱うのは，その確認行為そのものを信頼できるものにする層，すなわち（C）系統である．CAA 確認も DCV も，その途中で DNS を引く以上，引いた答えが本物でなければ意味をなさない．MPIC と DNSSEC は，まさにその引いた答えの真正性を支える．

第一の柱が MPIC である．MPIC（Multi-Perspective Issuance Corroboration，複数視点による発行裏付け）は，2024 年に可決された Ballot SC067v3 によって導入された要件で [18]，2025 年 3 月 15 日に適用が始まった．ただし当初は，裏付け結果の不一致を発行のブロックに反映させるか否かが CA の裁量に委ねられており，ブロックが必須となったのは 2025 年 9 月 15 日からである．その骨子は，ドメイン管理権の確認と CAA チェックを，単一のネットワーク経路からではなく，地理的・経路的に分散した複数のネットワーク視点（Network Perspective）から実施し，主たる視点（Primary Network Perspective）の結果を他の視点で裏付けるというものである．この要件が防ごうとしているのは，BGP ハイジャックに代表される経路詐取攻撃である．経路の乗っ取りや DNS 層への攻撃によって正規の CA から証明書を不正取得できることは，実証研究によって具体的に示されている [1], [2]．攻撃者が特定の経路だけを乗っ取って DNS 応答や HTTP 応答を偽装できたとしても，複数の異なる視点から観測すれば，乗っ取られていない視点が食い違いを検出する．こうした多視点の検証を大規模 CA で実運用した報告もある [3]．観測点を一点に集中させないことが，DNS を引くという行為そのものの堅牢性を底上げする．

第二の柱が DNSSEC である [19], [20], [21]．2025 年 6 月に可決された Ballot SC085v2 は，CAA レコードの取得や DCV 関連の DNS ルックアップにおいて，DNSSEC の検証を必須とした [22]．この要件は 2026 年 3 月 15 日に適用が始まっている．この要件は誤解されやすいため，正確に述べておく．まず押さえるべきは，この要件が課す義務の所在である．SC085v2 が義務づけているのは，CA の側の検証行為である．対象ゾーンが DNSSEC で署名されている場合，CA は CAA や DCV に関わる DNS ルックアップにおいて，IANA DNSSEC ルートトラストアンカーまで遡って署名を検証しなければならず，ローカルポリシーによって検証を無効化してはならない．要件の名称が「Require Validation of DNSSEC (when present)」，すなわち署名が存在する場合に検証を必須とするとなっている点がその核である．署名が存在するならば検証せよというのが趣旨であって，署名そのものを存在させよという要求ではない．

ここから導かれる帰結は二つある．一つは，SC085v2 がドメイン所有者（加入者）に DNSSEC の導入を義務づけるものではないという点である．DNSSEC を有効にしていないゾーンに対しては，CA は従来どおり検証なしで DNS レコードを扱う．したがって，DNSSEC 未導入の機関にとって，この要件は実質的に何の影響も及ぼさない．もう一つは，ひとたび DNSSEC を導入した場合には，その設定の健全性が証明書発行の前提条件になるという点である．DNSSEC が有効なゾーンでは，CA は検証を必須で行わなければならない．そしてその検証に失敗すれば，たとえば署名の期限切れ，鍵ロールオーバーの失敗，DS レコードと DNSKEY の不整合などによって，CA はその DNS 応答

© 2026 Information Processing Society of Japan

を信頼できないものとして扱い，問題が解決されるまで発行は止まる．署名や鍵管理の不備が現実の DNSSEC 運用に広く存在することは，大規模な測定研究が示すとおりである [4]．整理すると，DNSSEC を使わなければ影響はなく，正しく使えばむしろ DNS スプーフィングへの耐性が高まるが，使っていて設定を壊した場合には，従来は無視されて発行できていたはずの証明書が今後は発行不能になる．導入は任意だが，導入したなら正しく保つことが求められるという非対称な構造である．

DNSSEC の署名がどの単位で行われるかは，運用設計に直結する技術的事実なので，ここで明確にしておく．その設定不備が実際にどこまで影響を及ぼすかという実務的な帰結は，5.1 節で扱う．DNSSEC の署名は，個々の FQDN やレコードを選んでオン・オフするものではなく，ゾーン単位で行われる．あるゾーンに署名すると，そのゾーン内のすべてのレコード集合が署名対象になる．存在しないことまでを署名で証明する設計（NSEC/NSEC3）上，ゾーン内の一部のレコードだけを署名するという選択は成立しない [23]．したがって，証明書を取りたい FQDN だけを DNSSEC 化するといった細かい出し分けは，原則としてできない．粒度を分けたい場合の唯一の方法は，ゾーンを分割すること，すなわち委任である．たとえば `sub.example.ac.jp` を NS レコードで別ゾーンに委任すれば，親ゾーンと子ゾーンはそれぞれ独立に署名の有無を持てる．子ゾーンの DS レコードを親に登録すればセキュアな委任となり，署名チェインが親から子へ繋がる．登録しなければインセキュアな委任となり，その先は検証対象外として扱われる．このゾーン単位という原則は，5.1 節で述べる影響範囲の議論の土台になる．署名はゾーンでまとまっている以上，その健全性が崩れたときの影響もゾーン単位でまとまって現れるからである．

4.4 時系列で見る DNS と証明書の接近

ここまでは，DNS が証明書発行に関わる三つの系統を，テーマごとに縦に追ってきた．視点を変えて，これらを時間軸に並べ直すと，DNS への依拠が段階的に，かつ近年になって加速的に深まってきた様子が一望できる（**表 1**）．

参考として，IP アドレス向けの逆引き（Reverse Address Lookup）を用いた旧来の検証方式が廃止され，IP アドレスについても DNS-TXT ベースの永続方式へ移行している（SC091，2025 年 12 月適用開始）[24]．これは本稿が主題とする FQDN ベースの証明書管理からはやや周縁的な動きだが，DNS ベース方式への集約という全体の潮流を裏づける一例である．

この年表が示すのは，二つの傾向である．第一に，関与する系統が（A），（B），（C）のすべてにわたって厚みを増していること．第二に，その変化が 2025 年から 2026 年にかけて集中していることである．MPIC と DNSSEC 検証必須化がわずか一年のあいだに相次いで適用開始を迎え，CAA パラメータ処理の必須化も可決済みで，2027 年 3 月の適用開始を待つ段階にある．証明書発行と DNS の結びつきは，いままさに最も急速に強まっている局面にある．

5. DNS を含めた新たな運用体制の構築

ここまでの各節は，突き詰めれば CA が発行にあたって何を確認するかという，CA 側の処理の話であった．しかし，その帰結は CA ではない側，すなわち証明書の発行を申請する加入者と，サーバや DNS を実際に管理する運用者の側に返ってくる．CA が DNS を引いて発行可否を決める以上，引かれる側の DNS の状態は，自らの証明書が発行できるか否かを直接左右するからである．ここで管理の主語が転換する．これまで DNS は，利用者にとって名前を正しく引かせるためのインフラであった．だが，いまやそれは証明書を発行させられるかどうかを決める要素になった．CA 側の仕組みの変化が，加入者側の管理責任の拡張として跳ね返ってくる．この転換を踏まえて，本節ではまず実務上の含意を整理し，続いてそれを統制の仕組みとして組み立てる．

5.1 実務への含意

第一に，管理対象が拡張された．冒頭で述べた従来の三点，すなわち鍵，設定，発行状況に，第四の管理対象として DNS の健全性が加わった．これは抽象的なスローガンではなく，具体的な管理項目を伴う．その典型が，4.2 節で触れた永続的 TXT レコード方式（SC088v3）である．従来の都度設置型の DCV では，検証用の DNS レコードは検証が終われば消してよい使い捨てであった．ところが永続方式では，同じレコードを有効期限まで置き続ける．これは利便性の向上であると同時に，そのレコードが維持・管理すべき資産になったことを意味する．置きっぱなしにする以上，そのゾーンが侵害されれば，攻撃者はそのレコードを使って長期間にわたり証明書を不正取得しうる．役割を終えたまま放置された DNS レコードが乗っ取りの足がかりになることは，dangling DNS レコードに関する研究が早くから警告してきたとおりである [6]．検証用レコードの棚卸しと保護が，新たな管理項目として立ち上がるのである．CAA についても同様の含意がある．CAA は発行を制御できる仕組みであり，一見すると加入者にとって有益な機能にすぎない．だが裏を返せば，CAA 設定の誤りは発行を止めうるということでもある．実際，チェック義務化直後の測定では，設定に不備のある CAA レコードが少なからず観測されている [5]．許可すべき CA をレコードに書き忘れれば，正規の更新が拒否される．逆に，`accounturi` によって発行を特定アカウントに縛れば，不正発行への防御を一段強められる．管理できることが増えたことは，そのまま管理すべき項目が増えたことに等しい．

© 2026 Information Processing Society of Japan

表 1 DNS と証明書の接近の年表
Table 1 Timeline of the convergence between DNS and certificate issuance.

時期（適用開始）	標準/要件	系統	内容
2013 年	RFC 6844	（A）	CAA レコードの標準化（当初は任意）
2017 年 9 月 8 日	Ballot 187	（A）	CAA チェックの必須化
2019 年 11 月	RFC 8659 / RFC 8657	（A）	CAA の再編，accounturi/validationmethods パラメータの定義
2025 年 3 月 15 日	SC067v3	（C）	MPIC，DCV と CAA 確認の複数視点裏付け（ブロック必須は同年 9 月 15 日から）
2025 年 11 月 11 日	SC088v3	（B）	永続的 TXT レコードによる DCV 方式
2026 年 3 月 15 日	SC085v2	（C）	DNSSEC 検証の必須化（署名が存在する場合）
2027 年 3 月 15 日	SC098v2	（A）	RFC 8657 CAA パラメータの処理必須化

第二に，設定不備の影響範囲が広い．4.3 節で確認したとおり，DNSSEC の署名はゾーン単位である．この技術的事実は，実務的には影響範囲の問題として現れる．DNSSEC を有効にしたゾーンで，鍵ロールオーバーに失敗したり，DS レコードの登録に不備があったりすると，検証は失敗する．とりわけ鍵の更改は，DNSSEC 運用のなかでも誤りが生じやすい作業として知られている [8]．そして検証の失敗は，そのゾーン配下のすべての FQDN に一斉に及ぶ．特定の一台のサーバの証明書だけが止まるのではなく，そのゾーンに属する全ホストの証明書発行・更新が，まとめて立ち行かなくなる．一つの設定ミスが，面で影響する．ここで認識を改めるべきは，これがもはや DNS 単独の問題ではないという点である．DNS の設定不備は，従来であれば名前が引けないという DNS 層の障害にとどまった．しかし現在では，それが証明書の発行・更新の停止に直結し，ひいては証明書を必要とするサービスそのものの可用性を脅かす．DNS の障害が，証明書の障害を経由して，サービスの障害へと連鎖する経路ができあがったのである．

第三に，運用体制への示唆がある．管理対象の拡張と影響範囲の拡大は，組織の体制にも影響する．多くの組織では，証明書の管理と DNS の管理が，別々の担当者・別々のチームに分かれている．証明書担当は鍵と更新を見て，DNS 担当はゾーンとレコードを見るという分業である．しかし，これまで述べてきたとおり，両者はもはや独立していない．証明書が更新できない原因が，DNSSEC の鍵ロールオーバーや CAA の設定にあるという事態は，今後ごく普通に起こりうる．そのとき，証明書担当が DNS の状態を把握しておらず，DNS 担当が自らの変更が証明書に及ぼす影響を意識していなければ，原因の切り分けすら難航する．鍵ロールオーバーや DS 登録の作業を行う際に，それが配下の全証明書に影響しうるという認識を，両担当が共有しておく必要がある．証明書と DNS の連携は，もはや任意の改善策ではなく，可用性を守るための前提条件である．ただし，こうした連携を個々の担当者の注意力や善意に委ねたままでは，担当の交代や繁忙の波とともに容易に途切れる．認識を持続する仕組みに変えるには，DNS の変更と状態を組織として統制する枠組みが要る．次節では，その枠組みを，審査と監査という二つの営みと，それらを支える体制の整備として述べる．

5.2 DNS 管理を統制する

前節で見たとおり，DNS の状態は証明書の発行可否を左右し，その影響はゾーン単位で面的に及ぶ．この性質を持つ対象を管理する定石は，変更の前に確かめ，変更の後も定期的に確かめるという二段構えである．すなわち，変更時の審査と，定期の監査である．本項では，この二つに，それらを支える体制と手続きの整備を加えた三つの類型として，DNS 管理を統制する方法を示す．なお，ここで挙げる項目は組織の規模や体制によって具体化の形が変わるため，個別の手順ではなく確認すべき観点の類型として述べる．

第一が審査，すなわち変更の前に行うチェックである．証明書に影響しうる DNS の変更は，実行前にその影響を確認する対象とすべきである．典型は，DNSSEC に関わる作業である．鍵ロールオーバー，DS レコードの登録・変更，委任構成の変更はいずれも，失敗すればそのゾーン配下の全 FQDN の証明書発行を止めうる．これらの作業の実施前に，配下でどの証明書が発行・更新の予定を持つかを確認し，作業の時期と手順を証明書のライフサイクルと突き合わせる審査が要る．CAA レコードの変更も同様である．利用中の CA が許可の列挙から漏れていないか，`accounturi` 等のパラメータを用いる場合はそれが実際の発行アカウントと整合しているかを，変更を適用する前に確かめる．検証用レコードを置くゾーンの構成変更や，委任のセキュア・インセキュアの切り替えも，DCV や DNSSEC 検証の対象範囲を変えるため，発行フローへの影響を事前に評価する対象に含める．

第二が監査，すなわち定期的または事後に行う検証である．審査が変更の入口を守るのに対し，監査は時間の経過とともに生じるずれを検出する．CAA レコードの棚卸しでは，記載された CA が現に利用している CA と一致しているか，利用をやめた CA が残っていないかを確認する．

© 2026 Information Processing Society of Japan

検証用レコードの棚卸しでは，都度設置型のレコードに削除漏れがないか，永続型のレコードについては，それが認可する先のアカウントがいまも正当に管理されているかを確かめる．DNSSEC を導入しているゾーンでは，署名の有効期限や署名チェインの健全性を定期的に検証する．そして，これらの DNS 上の状態を証明書のインベントリと突き合わせ，DNS 側の記載と実際の証明書利用とのあいだに乖離がないかを点検する．監査の間隔は，証明書の有効期間が段階的な短縮に向かっている趨勢 [25] を踏まえ，年に一度といった従来の感覚よりも短く設定することが望ましい．

第三が体制と手続きの整備である．審査と監査は，それを担う主体と手続きが定まってはじめて機能する．まず，ゾーンごと，レコード種別ごとに，誰が変更を承認し誰が実施するのかという責任分界を明文化する．そのうえで，DNS の変更承認フローに証明書担当が関与する経路を設ける．前節で述べた分業の断絶を埋めるのは，担当者間の自発的な声かけではなく，承認フローという手続きだからである．逆に，証明書の新規取得や更新方式の変更が DNS レコードの追加を伴う場合には，DNS 担当がそれを把握できる経路も要る．関与は双方向でなければならない．さらに，インシデント対応の手順に，DNS 起因の発行停止という障害類型をあらかじめ組み込んでおく．証明書が更新できないという事象の背後に DNSSEC の署名不全や CAA の設定誤りがある場合，この類型を知らない担当者には原因が見えない．切り分け手順の冒頭に，DNS の健全性確認を置いておくだけで，復旧までの時間は大きく変わる．

なお，変更の前に確かめ，変更の後も定期的に確かめるという本項の骨格は，情報セキュリティマネジメントの一般的な枠組みと地続きである．情報セキュリティマネジメントシステムの要求事項を定める ISO/IEC 27001 は変更の管理と定期的な監視・レビューを求め [26]，IT サービスマネジメントの枠組みである ITIL は変更の事前評価と承認を基本動作とする [27]．本項の提案はこれらを置き換えるものではなく，その基本動作を証明書と DNS の接点に特殊化したものである．ただし，汎用の枠組みをそのまま適用しても，CAA レコードと利用 CA の整合，DS 登録と証明書更新予定の突合，検証用レコードの棚卸しといった証明書固有の確認項目はおのずと導かれない．統制の一般論と証明書実務のあいだにあるこの間隙を，確認すべき観点の類型として具体的に埋めた点に，本項の意味がある．

5.3 認識から統制へ

ここまで述べてきた変化に対して，まず求められるのは認識である．証明書の管理が，鍵・設定・発行状況に加えて DNS の健全性にまで及ぶようになったこと，両者の関係が不可分になったことを，運用者は正しく理解する必要がある．しかし，認識はあくまで出発点にすぎない．DNS の設定不備が証明書の発行を止め，それがサービスの可用性を脅かす経路が現実に存在する以上，DNS の健全性は，もはや DNS 層だけの関心事ではなく，証明書とサービスの可用性の問題として扱われなければならない．鍵ロールオーバーの手順，DS 登録の確認，CAA レコードの棚卸し，検証用レコードの保護といった作業を，証明書のライフサイクル管理と同じ重みで，運用設計のなかに明示的に組み込むことが求められる．そして，運用設計に組み込むとは，突き詰めれば前節で述べた統制の仕組み，すなわち変更の前に確かめる審査と，時間の経過を追って確かめる監査を，体制と手続きの裏づけとともに回し続けることにほかならない．

6. おわりに

本稿では，サーバ証明書の発行が DNS に構造的に依拠するようになった経緯と，それが運用にもたらす帰結について述べた．2 節で DNS が証明書発行に関与する三つの系統を整理し，3 節で先行研究に対する本稿の位置づけを示した．4 節では，発行可否の制御，ドメイン管理権の確認，確認の信頼性担保のそれぞれについて標準と要件の積み重ねを追い，時系列に並べ直すことで，変化が 2025 年から 2026 年に集中していることを確かめた．5 節では，その帰結として管理の主体が CA 側から加入者と運用者の側へ転換し，管理対象が DNS の健全性にまで拡張されたことを論じ，これに基づいて DNS 管理を審査・監査・体制の三つの類型で統制する枠組みを提案した．

DNS は，証明書管理における信頼境界になった．境界とは，認識するだけで守られるものではなく，事前の審査と継続的な監査によって守られるものである．その境界を，認識の対象から統制の対象へと引き上げることが，本稿の結論である．

参考文献

[1] Birge-Lee, H. et al.: Bamboozling Certificate Authorities with BGP, Proc. 27th USENIX Security Symposium, pp.833-849 (2018).

[2] Brandt, M. et al.: Domain Validation++ For MitM-Resilient PKI, Proc. 2018 ACM SIGSAC Conference on Computer and Communications Security, pp.2060-2076 (2018).

[3] Birge-Lee, H. et al.: Experiences Deploying Multi-Vantage-Point Domain Validation at Let's Encrypt, Proc. 30th USENIX Security Symposium, pp.4311-4327 (2021).

[4] Chung, T. et al.: A Longitudinal, End-to-End View of the DNSSEC Ecosystem, Proc. 26th USENIX Security Symposium, pp.1307-1322 (2017).

[5] Scheitle, Q. et al.: A First Look at Certification Authority Authorization (CAA), ACM SIGCOMM Computer Communication Review, Vol.48, No.2, pp.10-23 (2018).

[6] Liu, D., Hao, S. and Wang, H.: All Your DNS Records Point to Us: Understanding the Security Threats of Dangling DNS Records, Proc. 2016 ACM SIGSAC Con-

© 2026 Information Processing Society of Japan

ference on Computer and Communications Security, pp.1414-1425 (2016).
[7] Aas, J. et al.: Let's Encrypt: An Automated Certificate Authority to Encrypt the Entire Web, Proc. 2019 ACM SIGSAC Conference on Computer and Communications Security, pp.2473-2487 (2019).
[8] Müller, M. et al.: Rolling With Confidence: Managing the Complexity of DNSSEC Operations, IEEE Transactions on Network and Service Management, Vol.16, No.3, pp.1199-1211 (2019).
[9] 森下泰宏：向き合おう、DNS とサーバー証明書，Internet Week ショーケース in 広島，日本レジストリサービス (2018).
[10] Hallam-Baker, P. and Stradling, R.: DNS Certification Authority Authorization (CAA) Resource Record, RFC 6844, IETF (2013).
[11] CA/Browser Forum: Ballot 187 - Make CAA Checking Mandatory (online), 入手先 ⟨https://cabforum.org/2017/03/08/ballot-187-make-caa-checking-mandatory/⟩ (参照 2026-08-19).
[12] Hallam-Baker, P., Stradling, R. and Hoffman-Andrews, J.: DNS Certification Authority Authorization (CAA) Resource Record, RFC 8659, IETF (2019).
[13] Landau, H.: Certification Authority Authorization (CAA) Record Extensions for Account URI and Automatic Certificate Management Environment (ACME) Method Binding, RFC 8657, IETF (2019).
[14] CA/Browser Forum: Ballot SC098v2: Process RFC 8657 CAA Parameters (online), 入手先 ⟨https://cabforum.org/2026/05/13/ballot-sc098v2-process-rfc-8657-caa-parameters/⟩ (参照 2026-08-19).
[15] Barnes, R. et al.: Automatic Certificate Management Environment (ACME), RFC 8555, IETF (2019).
[16] CA/Browser Forum: Baseline Requirements for the Issuance and Management of Publicly-Trusted TLS Server Certificates (online), 入手先 ⟨https://cabforum.org/working-groups/server/baseline-requirements/documents/⟩ (参照 2026-08-19).
[17] CA/Browser Forum: Ballot SC-088v3: DNS TXT Record with Persistent Value DCV Method (online), 入手先 ⟨https://cabforum.org/2025/10/09/ballot-sc-088v3-dns-txt-record-with-persistent-value-dcv-method/⟩ (参照 2026-08-19).
[18] CA/Browser Forum: Ballot SC067v3: Require domain validation and CAA checks to be performed from multiple Network Perspectives Corroboration (online), 入手先 ⟨https://cabforum.org/2024/08/05/ballot-sc067v3-require-domain-validation-and-caa-checks-to-be-performed-from-multiple-network-perspectives-corroboration/⟩ (参照 2026-08-19).
[19] Arends, R. et al.: DNS Security Introduction and Requirements, RFC 4033, IETF (2005).
[20] Arends, R. et al.: Resource Records for the DNS Security Extensions, RFC 4034, IETF (2005).
[21] Arends, R. et al.: Protocol Modifications for the DNS Security Extensions, RFC 4035, IETF (2005).
[22] CA/Browser Forum: Ballot SC-085v2: Require Validation of DNSSEC (when present) for CAA and DCV Lookups (online), 入手先 ⟨https://cabforum.org/2025/06/18/ballot-sc-085v2-require-validation-of-dnssec-when-present-for-caa-and-dcv-lookups/⟩ (参照 2026-08-19).
[23] Laurie, B. et al.: DNS Security (DNSSEC) Hashed Authenticated Denial of Existence, RFC 5155, IETF (2008).
[24] CA/Browser Forum: Ballot SC-091: Sunset 3.2.2.5.3 Reverse Address Lookup Validation, proposal of new DNS-based validation using Persistent DCV TXT Record for IP addresses (online), 入手先 ⟨https://cabforum.org/2025/11/12/ballot-sc-091-sunset-3.2.2.5.3-reverse-address-lookup-validation-proposal-of-new-dns-based-validation-using-persistent-dcv-txt-record-for-ip-addresses/⟩ (参照 2026-08-19).
[25] CA/Browser Forum: Ballot SC081v3: Introduce Schedule of Reducing Validity and Data Reuse Periods (online), 入手先 ⟨https://cabforum.org/2025/04/11/ballot-sc081v3-introduce-schedule-of-reducing-validity-and-data-reuse-periods/⟩ (参照 2026-08-19).
[26] International Organization for Standardization: ISO/IEC 27001:2022, Information security, cybersecurity and privacy protection - Information security management systems - Requirements (2022).
[27] AXELOS: ITIL Foundation, ITIL 4 Edition, TSO (The Stationery Office), 212p. (2019).

© 2026 Information Processing Society of Japan